Arbiter MCP Firewall — Ship-to-Production Roadmap

> **Owner**: Security Engineering
> **Created**: 2026-04-16
> **Status**: DRAFT — Pending Principal Review
> **Baseline**: 25 tests passing | 73µs median latency | stdio transport only

---

Milestone Map

```
Week 1-2    Week 3-4      Week 5-8        Week 9-12       Week 13+
  |           |             |               |               |
  ▼           ▼             ▼               ▼               ▼
┌──────┐   ┌──────────┐   ┌────────────┐   ┌────────────┐   ┌──────────┐
│ M0   │   │  M1      │   │   M2       │   │    M3      │   │   M4     │
│Harden│→  │Protocol  │→  │ SetFit     │→  │ Transport  │→  │ Full MCP │
│      │   │Complete  │   │ Shadow     │   │ Security   │   │Compliance│
└──────┘   └──────────┘   └────────────┘   └────────────┘   └──────────┘
```

M0: Harden What Exists (Week 1-2)

Goal: Close all exploitable gaps in the current implementation without architectural changes.

M0.1 — Default-Deny for Unknown MCP Methods

- **What**: Change `Interceptor::process()` to REFUSE any method not in an explicit allowlist
- **Current behavior**: Only `tools/call` is evaluated; EVERYTHING ELSE returns `Allow`
- **New behavior**: Explicit allowlist: `ping`, `initialize`, `notifications/*`. Everything else gets policy evaluation or refusal
- **Acceptance**: Test that `resources/read`, `sampling/createMessage`, `prompts/get` are all refused by default
- **Latency budget**: 0µs additional (branch before existing code)

M0.2 — Payload Recursion Depth & Size Limit

- **What**: Add `max_depth: usize` (default 10) and `max_keywords: usize` (default 500) to `extract_payload_keywords()`
- **Current behavior**: Unbounded recursive JSON walk — DoS vector
- **Acceptance**: Test with 1000-depth nested JSON completes in <100µs (refusal, not OOM)
- **Latency budget**: <1µs (early exit)

M0.3 — Audit File Handle Reuse

- **What**: Open the audit file ONCE in `AuditChain::new()`, hold `BufWriter<File>`, flush per write
- **Current behavior**: Open/close on every `append()` — 67µs is almost entirely file handle overhead

- **Target latency**: <10µs per append
- **Acceptance**: Latency bench shows audit append median <15µs

M0.4 — Manifest Integrity Check

- **What**: SHA-256 hash of manifest file embedded at compile time via `include_str!` + `build.rs`. At runtime, verify file hash before loading
- **Not yet**: Full Ed25519 signing (M3). This is a tamper-detection stopgap
- **Acceptance**: Modified manifest file causes boot failure with clear error

M0 Exit Criteria

- [ ] Unknown MCP methods refused by default
- [ ] Payload extraction bounded
- [ ] Audit append <15µs median
- [ ] Manifest hash verified at boot
- [ ] All existing tests pass + 4 new tests
- [ ] Latency bench shows no regression on policy evaluation

M1: MCP Protocol Completeness (Week 3-4)

Goal: Intercept and evaluate ALL security-relevant MCP methods + egress logging.

M1.1 — Resource Method Interception

- **Methods**: `resources/read`, `resources/list`, `resources/subscribe`
- **Policy mapping**: Resource URI → Task with `task_type: "resource_read"`, payload includes URI
- **Boundary model**: New boundary category for resource access patterns (URI allowlists)
- **Acceptance**: `resources/read` of a blocked URI path returns refusal

M1.2 — Prompt & Sampling Interception

- **Methods**: `prompts/get`, `prompts/list`, `sampling/createMessage`
- **Policy mapping**: Prompt name or sampling content → Task for policy evaluation
- **Risk model**: `sampling/createMessage` is the highest-risk non-tool method (server-controlled LLM invocation)
- **Acceptance**: Sampling request with blocked content triggers refusal

M1.3 — Egress Audit Logging (Response Recording)

- **What**: Log server→client responses to the audit chain. DO NOT block responses (no FPR-tolerant model yet)
- **Schema**: New `AuditEntry` variant: `ResponseLogged { request_id, response_hash, flagged_keywords }`
- **Why not block**: Same keyword limitation applies. Without semantic understanding, blocking responses will hit the same 96% evasion + 46% FPR problem
- **Acceptance**: Every `tools/call` response has a corresponding audit entry with content hash

M1.4 — Concurrent Engine Architecture

- **What**: Refactor `Engine` to use `Arc<RwLock<PolicyEngine>>` for evaluation + `mpsc::UnboundedSender<AuditEntry>` for audit writes
- **New signature**: `Engine::evaluate(&self, task: Task) -> Result<Decision>`
- **Background writer**: Dedicated Tokio task consumes the channel, batches writes, calls `fsync()`
- **Acceptance**:
  - `Engine` is `Clone + Send + Sync`
  - 100 concurrent evaluations complete correctly
  - Audit file contains all 100 entries with valid hash chain
  - No `Mutex` on the hot path for policy evaluation (only `RwLock` read lock)

M1 Exit Criteria

- [ ] resources/, *prompts/*, sampling/* methods evaluated by policy
- [ ] Server responses logged to audit chain
- [ ] Engine is Send + Sync + Clone
- [ ] Concurrent evaluation test passes
- [ ] Latency bench: policy evaluation <5μs under contention
- [ ] 35+ tests passing

M2: SetFit Shadow Tier (Week 5-8)

Goal: Deploy SetFit as an async detection layer without impacting request latency.

M2.1 — SetFit Service Wrapper

- **What**: Python microservice wrapping the fine-tuned SetFit model (all-MiniLM-L6-v2, 22M params)
- **API**: gRPC unary `Classify(text) → {label, confidence, latency_ms}`
- **Deployment**: Sidecar container or localhost service
- **Model**: Load from the existing checkpoint (if FPR improved) or from `benchmarks/v2/setfit/` training pipeline

M2.2 — Async Shadow Evaluation

- **What**: After PreFlight allows a request, spawn a `tokio::spawn` task that sends the payload to SetFit
- **On SetFit REFUSE**: Write a `ShadowRefusal` audit entry with confidence score. Emit a metric/alert. Do NOT block
- **On SetFit ALLOW**: Write a `ShadowAllow` entry (for calibration analysis)
- **Configuration**: Feature-flagged. `manifest.shadow_tier.enabled = true`, `.endpoint = "http://localhost:50051"`

M2.3 — Feedback Loop: Shadow → PreFlight Hardening

- **What**: Weekly batch job that analyzes `ShadowRefusal` entries, extracts common keywords from SetFit-flagged-but-PreFlight-allowed payloads, suggests new `PolicyBoundary` entries
- **Output**: Proposed boundary additions in a review queue (human approves before deployment)
- **Goal**: Gradually close the semantic gap by converting ML detections into deterministic rules

M2 Exit Criteria

- ☐ SetFit service starts and responds in <25ms p99
- ☐ Shadow evaluation runs without blocking the request path
- ☐ ShadowRefusal audit entries are queryable
- ☐ At least one round of feedback-loop boundary generation tested
- ☐ Latency bench: zero regression on hot path (<5µs policy, <80µs total)

M3: Transport Security (Week 9-12)

Goal: Production-grade network security for HTTP deployment.

M3.1 — Streamable HTTP Proxy

- **What**: HTTP proxy mode alongside stdio. Listens on configurable port, proxies to upstream MCP server
- **Session management**: `MCP-Session-Id` header tracking, session state machine (initialize → active → closed)
- **Protocol negotiation**: `MCP-Protocol-Version: 2025-11-25` header enforcement

M3.2 — Authorization

- **OAuth 2.1**: RFC 9728 Protected Resource Metadata at `/.well-known/oauth-protected-resource`
- **Token validation**: Bearer token verification on every request
- **Per-client consent**: Stored in session, required before tool invocation
- **Dynamic client registration**: RFC 7591 for programmatic client onboarding

M3.3 — Transport Hardening

- **Origin validation**: Allowlist of permitted Origin headers (DNS rebinding defense)
- **Localhost binding**: Default to 127.0.0.1, require explicit flag for network binding
- **Rate limiting**: Token bucket per session, per tool, per minute. Exponential backoff on repeated refusals
- **TLS**: Required for non-localhost. mTLS optional for service-to-service

M3.4 — Manifest Signing (Ed25519)

- **What**: Replace M0.4 hash check with full Ed25519 signature verification
- **Key management**: Public key compiled into binary. Signing via CI/CD pipeline only
- **Audit**: Manifest load event includes signature verification result in audit chain

M3 Exit Criteria

- ☐ HTTP proxy mode functional with session management
- ☐ OAuth 2.1 token validation working
- ☐ Origin allowlist enforced
- ☐ Rate limiting active per session
- ☐ Manifest signed and verified at boot
- ☐ Penetration test: DNS rebinding, SSRF, session hijack all blocked
- ☐ 50+ tests passing

M4: Full MCP 2025-11-25 Compliance (Week 13+)

M4.1 — Tool Annotations

- Record `destructiveHint`, `readOnlyHint`, `openWorldHint` from `tools/list` responses
- Enforce stricter policy on destructive tools (require explicit manifest allowlist)
- Log annotation inconsistencies (tool claims readOnly but modifies state)

M4.2 — Structured Content & Output Schema

- Parse tool responses against declared `outputSchema`
- Log schema violations as potential tool misbehavior indicators

M4.3 — Multi-Modal Content Support

- Extend `Task` and `AuditEntry` to handle `image` and `audio` content types
- Content-hash images/audio for audit (don't keyword-extract binary content)
- Size limits on binary content pass-through

M4.4 — Elicitation Interception

- Intercept server `elicitation/create` requests
- Policy evaluation on requested data types (e.g., block requests for credentials)

M4.5 — Audit Chain V2

- Log rotation with cross-file hash chain continuity
- Compressed archival to object storage
- Query API for audit trail search (by session, time range, decision type)

M4 Exit Criteria

- [ ] Full MCP 2025-11-25 method coverage
- [ ] Multi-modal content handled safely
- [ ] Audit chain production-grade with rotation
- [ ] Compliance report generator
- [ ] 75+ tests passing
- [ ] External security audit scheduled

Latency Budget Tracker

Component	Current	M0 Target	M1 Target	M2 Target
PolicyEngine::evaluate	2-4μs	2-4μs	<5μs (under contention)	<5μs
AuditChain::append	67μs	<15μs	<5μs (channel send)	<5μs
Full Engine::evaluate	73μs	<25μs	<15μs	<15μs
MCP Interceptor	76μs	<30μs	<20μs	<20μs
SetFit shadow (async)	N/A	N/A	N/A	0μs on hot path

Component	Current	M0 Target	M1 Target	M2 Target
End-to-end	**76µs**	**<30µs**	**<20µs**	**<20µs**

> The 118µs research target was conservative. With file handle reuse and write-behind audit, we should achieve <20µs end-to-end for the deterministic path.

Risk Register

Risk	Likelihood	Impact	Mitigation
SetFit FPR remains >30%	HIGH	Blocks M2 deployment as even shadow tier	Invest in training data diversity (need 5000+ diverse negatives)
MCP spec changes pre-1.0	MEDIUM	Rework M3/M4	Track spec repo, design for transport abstraction
Audit chain corruption on crash	MEDIUM	Compliance failure	M0.3 fsync + M1.4 write-behind with flush guarantees
Attacker reads manifest and crafts bypass	HIGH	96% evasion rate	Known limitation. SetFit shadow tier is the long-term answer
Concurrent eval introduces lock contention	LOW	Latency regression	RwLock (read-heavy workload), benchmark under contention
Supply chain attack on dependencies	LOW	Full compromise	`cargo audit`, `cargo deny`, minimal dependency surface

---

Non-Goals (Explicitly Out of Scope)

- **Real-time ML blocking**: Until SetFit FPR <5%, we will NOT block on ML predictions
- **Custom model training**: We use the existing SetFit checkpoint. Model improvements are a research workstream, not an engineering one
- **Multi-server orchestration**: Arbiter guards ONE MCP server connection. Cross-server policy coordination is a future architecture decision
- **WebSocket transport**: MCP deprecated HTTP+SSE in favor of Streamable HTTP. We implement the current spec, not the deprecated one

---

This roadmap is a living document. Update after each milestone retrospective.